MODULE 39 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 4

The last twenty. Mixed difficulty, weighted as before, with the trickiest distractors of the four sets.

QUESTIONS 20 SUGGESTED TIME 40 minutes PASS GUIDE 14 of 20

admin@sthithapragna.com

A security team must forward a filtered subset of CloudWatch log events to a third-party SIEM in near real time, and separately must place a complete daily copy of the same log group into S3 for long-term archive.

The SIEM ingests from Amazon Data Firehose.

What should the team configure?

A Two export tasks to S3, one of which the SIEM reads

B A subscription filter to Firehose for the SIEM, and a scheduled export task to S3 for the archive

C A subscription filter to S3, and Logs Insights queries for the SIEM

D A metric filter for the SIEM and a subscription filter for the archive

◆ PAUSE AND DECIDE

What should the team configure?

A. Two export tasks

Export tasks are bulk and batch, taking up to twelve hours to complete. Nothing about them is near real time.

B. Subscription filter plus export task

Two requirements with opposite shapes: continuous filtered streaming is a subscription filter; a complete periodic copy is an export task.

C. Subscription to S3, Insights for SIEM

Inverts both halves. Logs Insights is an interactive query tool and cannot push to a SIEM continuously.

D. Metric filter for the SIEM

A metric filter produces a numeric metric, not log events. The SIEM needs the events themselves.

THE SIGNAL

Streaming versus bulk copy. A subscription filter is continuous and filtered; an export task is periodic and complete.

An operations team receives roughly forty alarm notifications during any single database failover, because dozens of dependent service alarms fire at once. They want one notification describing the underlying problem, while keeping the individual alarms visible on dashboards.

They do not want to delete or disable any existing alarm.

What should the team implement?

A Increase the evaluation periods on all dependent alarms

B An alarm mute rule covering the failover window

C Delete the dependent alarms and keep only the database alarm

D A composite alarm whose rule suppresses child alarms when the database alarm is in ALARM, notifying only on the composite

◆ PAUSE AND DECIDE

What should the team implement?

A Longer evaluation periods

Delays every alarm equally, so you still get forty notifications, merely later. It also slows genuine detection.

B A mute rule

Suppresses by calendar, for known windows such as maintenance. A failover is unplanned, so there is no window to schedule.

C Delete the dependents

Explicitly ruled out, and it destroys the per-service visibility the team wants on dashboards.

D Composite alarm with suppression

Suppresses by logic rather than by calendar: children stay defined and visible, and only the composite notifies.

THE SIGNAL

Composite alarms suppress by logic; mute rules suppress by calendar. A failover is unplanned, so only one of those applies.

> An investigator must run ad hoc queries across three years of CloudTrail logs stored in S3. Those must be joined against a separate S3 dataset of employee identifiers. Queries will run a few times a month, with no infrastructure to manage.
>
> CloudTrail Lake is not in use.

What should the team use?

A Amazon Athena over the CloudTrail S3 data, partitioned by date

B CloudWatch Logs Insights over a log group containing the trail

C Onboard to CloudTrail Lake for its query engine

D Load the logs into an Amazon Redshift cluster

◆ PAUSE AND DECIDE

What should the team use?

A Athena over S3

Serverless, charged per terabyte scanned, and it joins across separate S3 datasets natively. Partitioning by date limits what each query scans.

B Logs Insights

Queries CloudWatch log groups, not S3. Retaining three years in a log group would also be far more expensive than S3.

C CloudTrail Lake

Closed to new customers on 31 May 2026, and the scenario confirms it is not in use. The team cannot onboard.

D Redshift

A cluster to manage and pay for continuously, for queries running a few times a month. The opposite of the stated requirement.

THE SIGNAL

Three years, in S3, joined against another dataset, a few times a month. Every clause points at Athena, and one clause closes the door on Lake.

> An operations team must automate a recovery runbook that stops an EC2 instance, detaches an EBS volume, snapshots it, attaches a replacement volume, and starts the instance again. Some steps must wait for the previous one to reach a given state, and the whole thing must be auditable.
>
> The instance may be unresponsive when the runbook runs.

What should the team use?

A Run Command with a shell script performing the sequence

B A State Manager association applying the steps on a schedule

C An SSM Automation runbook, which acts on AWS resources through APIs and supports waits between steps

D A Session Manager session with the commands typed manually

◆ PAUSE AND DECIDE

What should the team use?

A Run Command

Runs commands inside the operating system, which requires a responsive instance and cannot stop or start the instance it runs on.

B State Manager

Maintains a desired state continuously on a schedule. This is a one-off ordered sequence, not a state to enforce.

C Automation runbook

Automation acts on AWS resources through APIs, so it works on a stopped or unresponsive instance, and it supports waits and branching between steps.

D Manual session

Not automation at all, and it requires the instance to be responsive, which the scenario says it may not be.

THE SIGNAL

Automation acts on the AWS resource; Run Command acts inside the operating system. An unresponsive instance settles it immediately.

> An ECS service on Fargate must send application logs to both CloudWatch Logs and a third-party observability platform. Some log lines must be filtered out before leaving the container, configured in the task definition rather than in application code.
>
> The application writes to stdout.

What should the team use?

A The awslogs driver, configured with a filter pattern

B FireLens with a Fluent Bit sidecar, routing to both destinations with filtering

C A CloudWatch subscription filter on the log group

D The CloudWatch agent as a sidecar container

◆ PAUSE AND DECIDE

What should the team use?

A awslogs driver

Sends stdout to one CloudWatch log group. It supports no filtering and no second destination.

B FireLens with Fluent Bit

Configured in the task definition, routes to multiple destinations simultaneously, and filters or transforms before the logs leave the task.

C Subscription filter

Would fan out after the logs reach CloudWatch, so you still pay to ingest everything and nothing is filtered before leaving the container.

D CloudWatch agent sidecar

Collects metrics and logs from a host or files. It is not the ECS log routing mechanism, and FireLens exists for this.

THE SIGNAL

awslogs is one destination, no filtering. FireLens is many destinations, with filtering, configured in the task definition.

> An Auto Scaling group must respond differently depending on severity: a modest queue backlog should add two instances, while a severe backlog should add ten immediately. The team currently uses target tracking on queue depth per instance and finds it too slow to react to the severe case.
>
> Both thresholds are well understood from historical data.

What should the team configure?

A. A second target tracking policy with a lower target value

B. Predictive scaling in ForecastAndScale mode

C. Step scaling with two steps, adding 2 instances at the modest threshold and 10 at the severe one

D. A scheduled scaling action sized for the severe case

◆ PAUSE AND DECIDE

What should the team configure?

A Second target tracking policy

Target tracking aims at one value and works out the adjustment itself. Two policies compete; neither expresses different responses to different severities.

B Predictive scaling

Forecasts recurring patterns. A backlog spike driven by severity is not a time-of-day pattern, and predictive only scales out.

C Step scaling with two steps

Step scaling exists precisely to give different adjustments at different breach magnitudes. Two known thresholds map onto two steps.

D Scheduled action

Scales at a fixed time regardless of load. The trigger here is severity, not the clock.

THE SIGNAL

Target tracking answers "keep this number here". Step scaling answers "if it is this bad do this, if it is much worse do more".

> Users of an application behind an Application Load Balancer intermittently receive HTTP 502 responses. The target group shows all targets healthy, and the application logs show the affected requests being processed and returning a response.
>
> The application recently began returning a very large custom header on some responses.

What is the most likely cause?

A The target returned a malformed or oversized response the load balancer could not parse

B No healthy targets were registered at that moment

C The target did not respond within the idle timeout

D The deregistration delay is too short

◆ PAUSE AND DECIDE

What is the most likely cause?

A Malformed or oversized response

502 means the load balancer received something it could not parse. An oversized header exceeding the ALB's limit produces exactly this.

B No healthy targets

That produces 503, and the scenario states all targets are healthy.

C Idle timeout exceeded

That produces 504. The logs show the requests completing and returning a response, so nothing timed out.

D Deregistration delay

Governs draining for removed targets. It does not cause a parse failure on a live response.

THE SIGNAL

502 answered badly, 503 nobody answered, 504 not in time. The oversized header is the clue that something was answered, and answered wrongly.

> A global application must survive the loss of an entire Region. The recovery point objective is about one second, and the recovery time objective is under one minute. The database is Aurora PostgreSQL and reads must be served locally in three Regions.
>
> Cost is secondary to the targets.

What should the team implement?

A. A cross-Region Aurora read replica promoted manually on failure

B. Automated snapshots copied cross-Region every 15 minutes

C. Aurora Multi-AZ in three Availability Zones

D. An Aurora global database with secondary Regions, using managed failover

◆ PAUSE AND DECIDE

What should the team implement?

A Cross-Region replica, manual promotion

Closer, and manual promotion cannot reliably meet a one-minute RTO, and it does not provide the managed multi-Region model described.

B Snapshots every 15 minutes

An RPO of fifteen minutes at best, against a requirement of about one second. Off by three orders of magnitude.

C Multi-AZ

Protects against the loss of an Availability Zone, not a Region. The requirement is explicitly Regional.

D Aurora global database

Built for this: typical sub-second replication lag, secondary Regions serving local reads, and managed failover measured in well under a minute.

THE SIGNAL

Multi-AZ is zone-level and a global database is Region-level. The one-second RPO alone eliminates anything snapshot-based.

A regulator requires that backup copies of financial systems cannot be deleted early for seven years. That explicitly includes the account root user and anyone at AWS. The team uses AWS Backup.

A 72-hour cooling-off period before the lock takes effect is acceptable.

What should the team configure?

A A backup vault with an IAM policy denying delete operations

B AWS Backup Vault Lock in compliance mode

C AWS Backup Vault Lock in governance mode

D Cross-Region copies of every recovery point

◆ PAUSE AND DECIDE

What should the team configure?

A IAM policy denying deletes

Whoever can write IAM policies can rewrite this one. A policy cannot bind the people who control policies.

B Vault Lock compliance mode

Once the cooling-off period elapses the lock is immutable: not the root user, not AWS, nobody can shorten retention or delete early.

C Governance mode

Designed to be removable by a principal with sufficient permissions. The requirement says nobody, which rules it out.

D Cross-Region copies

Protects against a Regional event. It does nothing to prevent early deletion, and a deletion could apply to copies too.

THE SIGNAL

"Including the root user" appears again, and here it extends to AWS itself. The 72-hour cooling-off period is the tell for compliance mode.

> A networking team owns a stack exporting a VPC ID and subnet IDs. Six application stacks, owned by different teams, import those values. The networking team now needs to replace the VPC, and CloudFormation refuses to delete or modify the exported outputs.
>
> Application teams deploy on their own schedules.

What explains this, and what is the better long-term pattern?

A Exports can be changed at any time; the error is unrelated

B Convert the six application stacks into nested stacks of the networking stack

C An export cannot be modified or deleted while another stack imports it. Consider SSM Parameter Store for values crossing ownership boundaries

D Delete all six application stacks first, then recreate them

◆ PAUSE AND DECIDE

What explains this, and what is the better long-term pattern?

A Exports are freely changeable

They are not. That rigidity is the entire point of the mechanism and the cause of the error.

B Nested stacks

Nested stacks share one lifecycle under one owner. Here six teams deploy independently, which is exactly when nesting is wrong.

C Locked while imported; use Parameter Store

An export is deliberately immutable while imported. A Parameter Store parameter is read at deploy time and creates no such lock.

D Delete all six stacks

Would work and requires coordinated downtime across six teams. It also does nothing to prevent a repeat.

THE SIGNAL

Exports are a hard dependency by design. That is a feature when you want protection and a problem when ownership boundaries differ.

> A platform team maintains infrastructure that differs per environment: production has three Availability Zones and read replicas, staging has two AZs and none, and development has one. The team currently maintains three near-identical CloudFormation templates that drift apart.
>
> They want the environment differences expressed as logic, with type checking and unit tests.

What should the team adopt?

A The AWS CDK, synthesising CloudFormation from code with per-environment logic

B One CloudFormation template with many Conditions and nested Fn::If expressions

C Three separate StackSets, one per environment

D Terraform with three workspaces

◆ PAUSE AND DECIDE

What should the team adopt?

A The AWS CDK

Loops, conditionals, type checking and unit tests in a real language, synthesising to CloudFormation. Named in exam guide skill 3.1 alongside CloudFormation.

B Conditions and Fn::If

Possible and rapidly unreadable. Conditions express choices, not logic, and there is no type checking or unit testing.

C Three StackSets

StackSets deploy one template to many targets. They do not express per-environment structural differences.

D Terraform workspaces

A reasonable alternative, and it adds a second toolchain and state management for a team already invested in CloudFormation.

THE SIGNAL

"Expressed as logic, with type checking and unit tests" is the CDK clause. Conditions are choices; the CDK gives you a programming language.

A company must be able to run its containerised platform from a second Region within 30 minutes. EKS cluster definitions are in code and the data layer replicates continuously. During a recovery test the cluster came up correctly but every pod failed with ImagePullBackOff.

All container images are stored in ECR in the primary Region only.

What should the company implement?

A ECR pull through cache in the recovery Region, configured against the primary Region's registry

B Enhanced scanning on the ECR repositories

C An ECR lifecycle policy retaining more image versions

D ECR cross-Region replication rules, so images exist in the recovery Region

◆ PAUSE AND DECIDE

What should the company implement?

A Pull through cache from the primary

The tempting one. A cache populates on first pull from an upstream source, and in a Regional failure that source is the Region that has failed.

B Enhanced scanning

Improves vulnerability detection. It does not place an image in another Region.

C Longer retention

Keeps more versions in the primary Region, which is the Region that is unavailable.

D Cross-Region replication

Images are copied to the recovery Region automatically and continuously, so they are already there when the primary Region is not.

THE SIGNAL

DR tests fail on the things that are not data. The cluster was fine, the data replicated, and there were no images.

> A nightly job must process about 500,000 records held in S3. Each record takes roughly two seconds and records are independent. The current implementation is a single Lambda function that loops and repeatedly hits the 15-minute timeout. The team needs per-record error handling and a report of which records failed.
>
> No servers are to be introduced.

What should the team use?

A Increase the Lambda timeout beyond 15 minutes

B An EC2 instance running the job as a script

C A Step Functions Distributed Map reading from S3, with Retry and Catch on the child workflow

D An SQS queue with one message per record and a Lambda consumer

◆ PAUSE AND DECIDE

What should the team use?

A Longer timeout

Fifteen minutes is Lambda's hard maximum and cannot be raised. 500,000 records at two seconds each is over eleven days serially anyway.

B An EC2 instance

Introduces a server, which the requirement forbids, and it runs serially unless you write the concurrency yourself.

C Distributed Map with Retry and Catch

Reads the dataset from S3, fans out across thousands of parallel child executions, and gives declarative per-record retry, catch and reporting.

D SQS with one message per record

A reasonable design that does parallelise the work. Per-record failure reporting means building it yourself from the DLQ.

THE SIGNAL

The arithmetic settles it before any service knowledge: 500,000 records at two seconds is over eleven days of serial work.

A role in account A must read objects from a bucket in account B. The bucket policy in account B allows s3:GetObject for that role's ARN. The role in account A has no S3 permissions at all in its identity policy. Requests fail with AccessDenied.

Both accounts are in the same organisation and there are no SCPs.

What must change?

A. Nothing; a resource policy naming the principal is sufficient

B. Add s3:GetObject on that bucket to the role's identity policy in account A

C. Add account B to the role's trust policy

D. Enable Block Public Access on the bucket

◆ PAUSE AND DECIDE

What must change?

A **Nothing needed**

True within a single account, and false across two. That single-account exception is exactly what makes this trip people up.

B **Grant it in the identity policy too**

Cross-account access is an AND. The bucket policy permits it, and the calling identity must independently be permitted to attempt it.

C **Change the trust policy**

Trust policies govern who may assume the role. Nobody is assuming anything; the role is calling S3 directly.

D **Block Public Access**

Governs public access. Nothing here is public, and enabling it would not grant anything.

THE SIGNAL

Cross-account is an AND, not an OR. Being in the same organisation changes nothing about that rule.

> An auditor requires evidence that 60 accounts comply with the CIS AWS Foundations Benchmark. That means automatic remediation where possible, and a single report of non-compliant resources. The team will not maintain the individual rules by hand.
>
> AWS Config is enabled everywhere and a delegated administrator is in place.

What should the team implement?

A. A Config conformance pack based on the CIS sample template, deployed organisation-wide, with a Config aggregator for reporting

B. Individual Config rules deployed to every account by a StackSet

C. GuardDuty enabled organisation-wide

D. Trusted Advisor security checks across the organisation

◆ PAUSE AND DECIDE

What should the team implement?

A CIS conformance pack plus aggregator

A sample pack is the standard as one deployable unit, remediation is included, and the aggregator gives the single cross-account report.

B Individual rules via StackSet

Achieves the same outcome and is exactly the hand-maintained rule set the requirement rules out. Conformance packs exist to replace this.

C GuardDuty

Detects malicious behaviour. It evaluates no configuration and maps to no compliance benchmark.

D Trusted Advisor

A useful fixed set of checks. It does not implement a named benchmark or give per-resource compliance evidence.

THE SIGNAL

A named standard, across every account, without maintaining rules by hand, is precisely what conformance packs were built for.

A security team wants GuardDuty enabled across the organisation. A network engineer objects that the cost will be prohibitive. He believes GuardDuty requires VPC Flow Logs and DNS query logging enabled and retained in every VPC, which the company does not do.

The team wants to understand the actual dependency.

What is correct?

A The engineer is right; flow logs must be enabled and retained first

B GuardDuty replaces the need for flow logs entirely for all purposes

C GuardDuty needs only CloudTrail; it does not use flow logs or DNS logs

D GuardDuty consumes CloudTrail, VPC Flow Logs and Route 53 DNS logs independently. You need not enable or pay for those logs yourself

◆ PAUSE AND DECIDE

What is correct?

A The engineer is right

A very common belief and wrong. GuardDuty's access to these sources is independent of any flow log configuration you create.

B GuardDuty replaces flow logs

Overstates it in the other direction. You may still want your own flow logs for troubleshooting and traffic analysis.

C CloudTrail only

Understates the foundational sources. Flow logs and DNS query logs are both used, alongside CloudTrail management events.

D Consumed independently

GuardDuty reads these sources directly, whether or not you have enabled them, and you are not charged for that consumption.

THE SIGNAL

GuardDuty reads flow logs even if you have never enabled VPC Flow Logs. That independence surprises people, and it is a cost argument in questions.

A company's NAT gateway charges have grown substantially. Analysis shows about 85 percent of the processed traffic is instances in private subnets reading from and writing to S3 and DynamoDB in the same Region. Instances must remain in private subnets.

The team wants the cheapest correct fix.

What should the team implement?

A. Gateway VPC endpoints for S3 and DynamoDB, with routes added to the private subnets' route tables

B. Interface endpoints for S3 and DynamoDB

C. A second NAT gateway to spread the load

D. Move the instances to public subnets with public IPs

◆ PAUSE AND DECIDE

What should the team implement?

A Gateway endpoints

Gateway endpoints exist for exactly these two services, are completely free, and remove 85 percent of the volume from the NAT gateway.

B Interface endpoints

Would work and costs per AZ per hour plus per GB. For S3 and DynamoDB specifically, the free gateway endpoint is the better answer.

C A second NAT gateway

Doubles the hourly charge and processes the same total volume. It increases cost.

D Public subnets

Violates the stated constraint, exposes the instances, and incurs per-hour public IPv4 charges for every one of them.

THE SIGNAL

Gateway endpoints exist for S3 and DynamoDB only, and they are free. That makes this the highest-value networking cost answer on the exam.

> Traffic between two VPCs attached to a Transit Gateway is inspected by stateful firewall appliances. Those sit in an inspection VPC, spread across three Availability Zones. Connections succeed most of the time and fail intermittently.
>
> The appliances log packets arriving for sessions they never opened.

What is the cause?

A. A missing route propagation in a Transit Gateway route table

B. Appliance mode is not enabled on the inspection VPC's Transit Gateway attachment

C. Security group referencing support is not enabled on the attachment

D. The appliances are undersized and dropping packets under load

◆ PAUSE AND DECIDE

What is the cause?

A Missing propagation

Would break connectivity consistently, not intermittently. The scenario says most connections succeed.

B Appliance mode not enabled

Without it the Transit Gateway may send the return path through a different AZ, so a stateful appliance receives a packet for a session it never opened.

C SG referencing support

A real Transit Gateway setting, and it would cause consistent denial for group-referencing rules, not asymmetric flows.

D Undersized appliances

The log message names sessions never opened, not exhausted resources. Capacity shows as drops under load, not orphaned packets.

THE SIGNAL

"Packets for sessions they never opened" is the asymmetric-routing signature. Intermittent rather than consistent points at path selection.

> A security team must stop workloads in 50 VPCs resolving known malware and command-and-control domains. They must also detect data exfiltration hidden inside DNS queries. The same policy must apply automatically to VPCs created later.
>
> Route 53 Resolver is in use throughout.

What should they implement?

A. A custom DNS Firewall domain list associated with each VPC

B. AWS Network Firewall in each VPC

C. Security group rules denying outbound port 53

D. DNS Firewall rule groups using AWS Managed Domain Lists and advanced threat detection, bundled into a Route 53 Profile shared through RAM

◆ PAUSE AND DECIDE

What should they implement?

A. Custom lists per VPC

Exactly the hand-maintained lists ruled out, associated 50 times, and a list can never catch tunnelling or generated domains.

B. Network Firewall

Inspects packets after a name has resolved. Useful alongside, and it does not stop the lookup or apply automatically to new VPCs.

C. Block outbound 53

Breaks all DNS resolution, since instances query the VPC resolver. It would take every workload offline.

D. Managed lists plus advanced detection, in a Profile

Managed lists remove the maintenance, advanced detection catches tunnelling no list contains, and a shared Profile covers VPCs created later.

THE SIGNAL

Three requirements: no manual lists, detect tunnelling, cover future VPCs. Managed lists, advanced detection and a Profile map onto one each.

A company has 90 branch offices and a large remote workforce, all of which must resolve names in Route 53 private hosted zones. Today each site runs a DNS server forwarding to Resolver inbound endpoints in two Regions, and the team maintains failover configuration at every site.

Remote workers have changing IP addresses and cannot be covered by source-IP rules.

What should the company consider?

A Inbound Resolver endpoints in more Regions

B Making the private hosted zones public

C Route 53 Global Resolver, using Access Sources for the offices and Access Tokens for remote workers

D A Route 53 Profile shared to each branch office

◆ PAUSE AND DECIDE

What should the company consider?

A More inbound endpoints

More of the thing causing the burden. Every site still needs forwarding and failover configuration maintained by hand.

B Make the zones public

Publishes internal DNS records to the entire internet, which is a serious disclosure of internal architecture.

C Global Resolver with both authorisation methods

Anycast addresses remove per-site failover configuration, Access Sources cover fixed-IP offices, and Access Tokens cover clients whose addresses change.

D A Profile per office

Profiles associate with VPCs. There is no way to associate one with a branch office network.

THE SIGNAL

The remote-worker clause is decisive: changing IPs cannot be authorised by source range, and Access Tokens exist precisely for that case.

You have finished the course

- **Four practice exams, 80 questions**, on top of 172 worked scenarios in the modules. Compare your domain breakdown across all four.
- **A domain weak in two or more sets** is where your remaining time belongs. A single bad set is noise.
- **Re-watch module 33 and drill module 34** in the final week. Those two carry the highest value per minute at that stage.
- **Review what you got right by luck** as carefully as what you missed. Luck does not repeat on the day.

> ON THE EXAM
>
> 130 minutes, 65 questions, no labs. Read the stem before the options, and the last sentence of every scenario twice. Good luck.